

GUÍA COMPLETA DE NMAP

Para el examen de Seguridad de Datos

Comandos, opciones, escaneo de redes, detección de servicios y evasión de cortafuegos

Contenido basado en la Práctica 4 – Monitorización y Auditoría de Seguridad

ANATOMÍA DEL COMANDO

Estructura básica

`nmap [opciones_de_timing] [opciones_de_scan] [opciones_de_target] objetivo`

Ejemplo completo comentado:

```
nmap -T4 -A -v www.epigijon.uniovi.es
      |      |      |
      Timing Agresivo Verbose    Objetivo
```

La opción `-A` es un alias de: `-O -sV -sC --traceroute`

- `-O` → detectar SO
- `-sV` → detectar versión de servicios
- `-sC` → ejecutar scripts NSE por defecto
- `--traceroute` → trazar la ruta hasta el objetivo

Especificación de objetivos

Objetivo	Ejemplo	Descripción
IP única	192.168.0.196	Un host concreto
Nombre de host	www.epigijon.uniovi.es	Resuelve por DNS
Subred CIDR	192.168.0.0/24	Toda la red /24 (256 hosts)
Rango de IPs	192.168.141-145.*	Rango de octetos
Comodín *	192.168.1.*	Todo el rango 0-255

CONSEJO: /24 cubre 192.168.0.0 → 192.168.0.255 (256 hosts). /16 cubre 65536 hosts.

Usar rangos pequeños en el examen para no esperar horas.

APARTADO 1: Timing Templates

Tabla de plantillas -T0 a -T5

Plantilla	Nombre	Comportamiento
-T0	Paranoid	Extremadamente lenta. Evita IDS/IPS.
-T1	Sneaky	Muy lenta. Útil para evadir sistemas de detección de intrusiones.
-T2	Polite	Lenta. Improbable que interfiera con el objetivo.
-T3	Normal	Plantilla por defecto si no se especifica ninguna.
-T4	Aggressive	Rápida. Recomendada en redes locales.
-T5	Insane	Muy rápida y agresiva. Puede perder resultados.

IMPORTANTE: En el examen usar siempre `-T4` para escaneos locales. Es el que usa Zenmap en el perfil "Intense scan" por defecto.

APARTADO 2: Fase 1 — Descubrimiento de Hosts (Ping Scan)

Objetivo de esta fase

Encontrar qué hosts están activos en la red antes de escanear sus puertos. Es más rápido que escanear puertos en todos los objetivos directamente.

Opciones principales de descubrimiento

-sn (No Port Scan — Ping Scan)

Solo descubre hosts activos, no escanea puertos. Rápido (segundos):

```
nmap -v -sn 192.168.0.0/24
```

CONSEJO: En versiones antiguas de Nmap esta opción se llamaba -sP. Si ves -sP en apuntes viejos es lo mismo que -sn.

-Pn (No Ping — Tratar todos como activos) -> Cortafuegos

Salta la fase de descubrimiento y escanea directamente todos los objetivos. Útil cuando el cortafuegos bloquea los pings:

```
nmap -v -Pn 192.168.0.0/24
```

IMPORTANTE: -Pn puede tardar más de 3 horas en una /24. Cancelar con Ctrl+C si tarda demasiado. En el examen usarlo solo en IPs concretas, no en subredes grandes.

Tipos de ping para la fase de descubrimiento

Opción	Tipo	Descripción
-PE	ICMP Echo Ping	El ping clásico. Muchos hosts lo bloquean por seguridad.
-PP	ICMP Timestamp Ping	Alternativa ICMP menos bloqueada por cortafuegos.
-PS	TCP SYN Ping	Envía SYN. Útil si el objetivo bloquea ICMP.
-PA	TCP ACK Ping	Envía ACK sin conexión previa. Alternativa a -PS.

Usando los cuatro combinados para maximizar descubrimiento:

```
nmap -v -PE -PP -PS -PA 192.168.0.0/24
```

CONSEJO: Combinar -PE -PP -PS -PA es la estrategia más completa para descubrir todos los hosts que no responden al ping ICMP estándar. Empieza por -sn y si faltan hosts, añade las opciones de ping adicionales.

APARTADO 3: Fase 2 — Escaneo de Puertos y Detección de Servicios

Sondeo TCP SYN (-sS)

Envía paquetes SYN sin completar el handshake (half-open). Más sigiloso que -sT:

```
nmap -sS 192.168.0.196
```

Detección de Sistema Operativo (-O)

Usa TCP/IP fingerprinting para identificar el SO del objetivo:

```
nmap -O 192.168.0.196
```

Si Nmap no detecta el SO con seguridad, forzar estimación:

```
nmap -O --osscan-guess 192.168.0.196
```

IMPORTANTE: Para que -O funcione correctamente, Nmap necesita encontrar al menos un puerto abierto Y un puerto cerrado en el host objetivo.

Detección de versión de servicios (-sV)

Identifica el software y versión que corre en cada puerto abierto:

```
nmap -sV 192.168.0.196
```

Ejemplo de resultado:

```
80/tcp open http Microsoft IIS httpd 10.0
443/tcp open ssl/http Microsoft IIS httpd 10.0
```

Escaneo de un puerto específico (-p)

```
nmap -sV -p 443 192.168.0.196      → solo puerto 443
nmap -sV -p 80,443,22 192.168.0.196 → puertos 80, 443 y 22
nmap -sV -p 1-1000 192.168.0.196   → rango de puertos 1 a 1000
```

Estado de los puertos en Zenmap

Estado	Semáforo	Descripción
open	Verde	Puerto abierto, servicio activo
closed	Rojo	Puerto cerrado, no hay servicio
filtered	Naranja	Cortafuegos bloquea la respuesta

APARTADO 4: Scripts NSE para SSL/TLS

Auditoría de cifrados TLS (-script ssl-enum-ciphers)

Lista todas las versiones TLS soportadas y sus conjuntos de cifrado, con una calificación de fortaleza por cada uno:

```
nmap -sV -p 443 --script ssl-enum-ciphers 192.168.0.196
```

También funciona sin -sV:

```
nmap -p 443 --script ssl-enum-ciphers 192.168.0.196
```

Interpretación de la letra de fortaleza:

Letra	Calificación
A	Fuerte – conjunto de cifrado robusto
B	Bueno – aceptable pero mejorable
C	Suficiente – débil, mejor evitar
D/E	Débil – no recomendado
F	Inseguro – vulnerabilidad conocida

IMPORTANTE: La última línea del output muestra "least strength: X" indicando el cifrado MÁS DÉBIL del servidor. Es lo que hay que mirar en el examen para evaluar la seguridad.

Ver el certificado SSL (-script ssl-cert)

Muestra información del certificado: emisor, validez, CN, etc.:

```
nmap -p 443 --script ssl-cert 192.168.0.196
```

Comprobar vulnerabilidad SSLv2 (-script sslv2)

Verifica si el servidor acepta SSL 2.0 (protocolo obsoleto y vulnerable):

```
nmap -p 443 --script sslv2 192.168.0.196
```

CONSEJO: Si el script no devuelve nada = no existe esa vulnerabilidad. Si devuelve resultados = el servidor ES vulnerable a SSLv2.

Comprobar vulnerabilidad Diffie-Hellman (-script ssl-dh-params)

Detecta debilidades en el intercambio de claves DH (ataque LOGJAM):

```
nmap -p 443 --script ssl-dh-params 192.168.0.196
```

APARTADO 5: Evasión de Cortafuegos

Fragmentación de paquetes (-f)

Divide los paquetes de sondeo en fragmentos de 8 bytes para intentar evadir cortafuegos que no reensamblan paquetes:

```
nmap -f 192.168.0.196
```

CONSEJO: Los sistemas de defensa modernos bien configurados detectan esta técnica. No es infalible.

Señuelos (Decoys) (-D)

Envía paquetes con IPs de origen falsas adicionales para disimular el escaneo real. El objetivo ve tráfico desde múltiples IPs:

```
nmap -sn -D 192.168.0.2,192.168.0.3 192.168.0.0/24
```

Usar señuelos aleatorios (RND:N):

```
nmap -sn -D RND:10 192.168.0.0/24
```

IMPORTANTE: Nmap sigue usando su IP real ADEMÁS de los señuelos. Solo dificulta identificar cuál es el atacante, no lo oculta completamente.

Puerto de origen falso (--source-port / -g)

Algunos cortafuegos aceptan tráfico de puertos conocidos (20=FTP, 53=DNS, 67=DHCP). Simula que el escaneo viene de uno de esos puertos:

```
nmap -sn -g 20 192.168.0.0/24 → simula origen FTP (puerto 20)
```

```
nmap -sn -g 53 192.168.0.0/24 → simula origen DNS (puerto 53)
```

```
nmap -sn --source-port 67 192.168.0.0/24 → simula origen DHCP
```

Puertos de origen que suelen engañar a cortafuegos:

Puerto 53 (DNS) → respuestas de resolución de dominios (el clásico de examen)

Puerto 20 (FTP) → transferencia de datos FTP en modo activo

Puertos 80 y 443 → tráfico de respuestas HTTP/HTTPS

Puerto 123 (NTP) → sincronización de reloj del sistema

Puerto 67 (DHCP) → asignación de direcciones IP

Añadir datos aleatorios (--data-length)

Añade bytes aleatorios al final de los paquetes para cambiar su tamaño y despistar sistemas que detectan patrones de tamaño típicos de Nmap:

```
nmap --data-length 25 192.168.0.196
```

Falsificación de MAC (--spoof-mac)

Cambia temporalmente la dirección MAC de origen. Puedes indicar una MAC concreta o pedir a Nmap que genere una de un fabricante:

```
nmap --spoof-mac Apple 192.168.0.196
```

CONSEJO: -ff duplica el tamaño de fragmento (16 bytes). --mtu <número> permite un tamaño a medida (debe ser múltiplo de 8).

CHULETA DE COMANDOS PARA EL EXAMEN

Comandos más frecuentes

Comando	Descripción
---------	-------------

<code>nmap -T4 -A -v IP</code> ↪ Zenmap)	Intense scan (perfil por defecto)
<code>nmap -v -sn IP/24</code> ↪ segundos)	Descubrir hosts activos (rápido,
<code>nmap -v -Pn IP</code> ↪ ICMP)	Escanear sin ping (evadir filtros)
<code>nmap -v -PE -PP -PS -PA IP/24</code>	Descubrimiento máximo combinado
<code>nmap -O IP</code>	Detectar sistema operativo
<code>nmap -sV IP</code>	Detectar versiones de servicios
<code>nmap -sS IP</code> ↪ sigiloso)	Sondeo TCP SYN (half-open, más
<code>nmap -O --osscan-guess IP</code>	Forzar estimación del SO
<code>nmap -p 443 --script ssl-enum-ciphers IP</code> ↪ A-F)	Auditar cifrados TLS (ver letra
<code>nmap -p 443 --script ssl-cert IP</code>	Ver certificado SSL
<code>nmap -p 443 --script sslv2 IP</code>	Comprobar vulnerabilidad SSLv2
<code>nmap -p 443 --script ssl-dh-params IP</code> ↪ (LOGJAM)	Comprobar vulnerabilidad DH
<code>nmap -sn -D RND:10 IP/24</code>	Escaneo con 10 señuelos aleatorios
<code>nmap -sn -g 53 IP/24</code>	Escaneo con puerto origen DNS
<code>nmap -f IP</code> ↪ (8 bytes)	Escaneo con paquetes fragmentados
<code>nmap --data-length 25 IP</code>	Paquetes con tamaño impredecible
<code>nmap --spoof-mac Apple IP</code>	MAC de origen falsificada

Opciones individuales de referencia rápida

Opción	Descripción
-T0 a -T5	Timing: T0=muy lento, T3=normal, T4=rápido, T5=insane
-A	Agresivo: -O + -sV + -sC + --traceroute
-v	Verbose: mostrar más detalles durante el escaneo
-sn	No escanear puertos (solo descubrimiento de hosts)
-Pn	No hacer ping (tratar todos los hosts como activos)
-PE	ICMP Echo ping
-PP	ICMP Timestamp ping
-PS	TCP SYN ping
-PA	TCP ACK ping
-sS	Sondeo TCP SYN (half-open)
-sV	Detectar versión de servicios
-O	Detectar sistema operativo
--osscan-guess	Forzar estimación del SO aunque no haya certeza
-p PUERTO	Especificar puerto(s) a escanear
--script NOMBRE	Ejecutar script NSE concreto
-f	Fragmentar paquetes en 8 bytes
-D IP1,IP2	Usar IPs como señuelos (decoys)
-D RND:N	Usar N señuelos aleatorios
-g PUERTO	Puerto origen falso (alias: --source-port)
--data-length N	Añadir N bytes aleatorios al final del paquete
--spoof-mac MAC	Falsificar dirección MAC de origen

Zenmap — Perfiles predefinidos y su comando equivalente

Perfil Zenmap	Comando equivalente
Intense scan	<code>nmap -T4 -A -v objetivo</code>
Intense scan + UDP	<code>nmap -sS -sU -T4 -A -v objetivo</code>

Intense scan, all TCP ports	<code>nmap -p 1-65535 -T4 -A -v objetivo</code>
Intense scan, no ping	<code>nmap -T4 -A -v -Pn objetivo</code>
Ping scan	<code>nmap -sn objetivo</code>
Quick scan	<code>nmap -T4 -F objetivo</code>
Quick scan plus	<code>nmap -sV -T4 -O -F --version-light objetivo</code>
Quick traceroute	<code>nmap -sn --traceroute objetivo</code>
Regular scan	<code>nmap objetivo</code>
Slow comprehensive scan	<code>nmap -sS -sU -T4 -A -v -PE -PP -PS80,443 -PA3389 -PU40125</code> ↪ <code>-PY -g 53 --script "default or (discovery and safe)" objetivo</code>

CONSEJO: Zenmap siempre muestra el comando Nmap equivalente al perfil seleccionado. Si necesitas un escaneo específico, edita el comando directamente en el campo "Comando". El campo "Perfil" quedará en blanco indicando que no usas perfil predeterminado.

Resumen del flujo de trabajo en el examen

1. **Descubrir hosts activos** → `nmap -v -sn IP/24`
2. **Analizar un host concreto** → `nmap -T4 -A -v IP_host`
3. **Ver puertos abiertos** → pestaña "Ports/Hosts" en Zenmap
4. **Detectar SO** → `-O` o ver en "Host Details"
5. **Auditar TLS/SSL** → `nmap -p 443 --script ssl-enum-ciphers IP`
6. **Buscar vulnerabilidades SSL** → `--script sslv2 y --script ssl-dh-params`

PREGUNTAS TIPO EXAMEN

Basado en [ExamenNMAP_Auditoria.md](#) — Bloques A y D.

Descubrimiento y escaneo básico

- a) Comando para descubrir hosts en `192.168.0.0/24` sin escanear puertos → `nmap -v -sn 192.168.0.0/24` (perfil Zenmap: **Ping scan**).
- b) Intense scan sobre `192.168.0.196` → `nmap -T4 -A -v 192.168.0.196` (`-A = -O -sV -sC --traceroute`).
- c) Semáforos Zenmap: verde = open, rojo = closed, naranja = filtered.
- d) Si el cortafuegos bloquea el descubrimiento → `-Pn`. Riesgo en `/24`: puede tardar **horas** (escanea los 256 hosts aunque no respondan al ping). Usar `-Pn` solo en **IPs concretas**.

Scripts NSE para SSL/TLS

- a) Auditar cifrados TLS en 443 → `nmap -sV -p 443 --script ssl-enum-ciphers IP`
- b) **least strength**: C = cifrado más débil aceptable en nivel **suficiente pero débil** (escala A→F).
- c) Comprobar SSLv2 → `nmap -p 443 --script sslv2 IP`. Sin salida = no vulnerable; con resultados = sí acepta SSLv2.
- d) Certificado del servidor → `nmap -p 443 --script ssl-cert IP`

Evasión de cortafuegos

- a) `-f` fragmenta en **8 bytes** (variante `-ff` = 16 bytes).
- b) Ping scan con 10 señuelos → `nmap -sn -D RND:10 192.168.0.0/24`
- c) Los señuelos **no ocultan** el origen: Nmap sigue enviando con tu IP real además de las falsas.

d) Simular origen DNS → `-g 53` o `--source-port 53`. Engaña a cortafuegos que confían en tráfico de puertos “legítimos”.

Nmap visto desde Wireshark (Bloque D)

a) Con `nmap -v -sn` en captura verás sondas ICMP (Echo, Timestamp), TCP SYN (p. ej. a 443) y TCP ACK (p. ej. a 80), sin escaneo completo de puertos.

b) Filtro destino al host escaneado → `ip.dst == 192.168.0.196` (ambos sentidos: `ip.addr == 192.168.0.196`).

c) `ssl-enum-ciphers` muestra el handshake TLS en claro; el contenido HTTPS va **cifrado** y Wireshark no lo lee sin claves de sesión.

d) Con `-sS` (half-open) **no** hay three-way handshake completo: SYN → SYN-ACK → **RST** (no se envía el ACK final).